

MARCO INTEGRATIVO GQM + PRAGMATIC

Trazabilidad desde Objetivos Nacionales hasta Métricas Técnicas FISMA FY2025

Kit GQM+PRAGMATIC — Documento (a) • Versión 1.0 • Abril 2026

"Una métrica sin objetivo es un número que busca sentido. Un objetivo sin métrica es un deseo que busca evidencia. GQM es el matrimonio de ambos — no siempre fácil, pero absolutamente necesario."

— Adaptación libre de Basili, Caldiera & Rombach (1994)

1. FUNDAMENTOS TEÓRICOS DEL MARCO INTEGRATIVO

1.1 La Metodología GQM: Tres Niveles de Trazabilidad

La metodología **Goal-Question-Metric (GQM)**, formulada por Victor Basili en el SEL/NASA (1984) y refinada en el Software Engineering Laboratory de la Universidad de Maryland, establece un paradigma de medición en tres niveles jerárquicos que garantiza la trazabilidad desde los propósitos estratégicos hasta los datos técnicos:

Nivel	Nombre	Descripción	Pregunta guía
Conceptual	GOAL (Objetivo)	Define qué se quiere conseguir, desde qué perspectiva y por qué	¿Por qué medimos?
Operacional	QUESTION (Pregunta)	Caracteriza el objeto de estudio en relación al objetivo	¿Qué necesitamos saber?
Cuantitativo	METRIC (Métrica)	Dato que responde la pregunta con información objetiva	¿Cómo lo sabemos?

Plantilla canónica de formulación de objetivos GQM:

Analizar [objeto de medición]
con el propósito de [propósito]
con respecto a [atributo de calidad/foco]
desde la perspectiva de [parte interesada]
en el contexto de [contexto organizacional o sectorial]

1.2 GQM+Strategies: La Extensión para Estrategias Nacionales

La extensión **GQM+Strategies** (Basili et al., 2007; Briand et al., 2014) resuelve la limitación original de GQM — su alcance exclusivamente de proyecto — añadiendo un nivel superior que conecta las **estrategias organizacionales y nacionales** con los objetivos de medición. Esta extensión es la que permite en este marco conectar:

Estrategia Nacional de Ciberseguridad (España 2025-2030)

↓ [GQM+Strategies: Strategy → Goal]

Objetivos institucionales (ENS, NIS2, FISMA adaptado)

↓ [GQM Nivel 1: Goal]

Objetivos de madurez por dominio

↓ [GQM Nivel 2: Question]

Preguntas de caracterización del estado de seguridad

↓ [GQM Nivel 3: Metric]

Indicadores técnicos FISMA FY2025 medibles

1.3 El Sistema PRAGMATIC: Metametrías para Evaluar Métricas

El sistema **PRAGMATIC** (Brothy & Hinson, *PRAGMATIC Security Metrics*, CRC Press/Taylor & Francis, 2013) proporciona nueve criterios de calidad para evaluar si una métrica de seguridad es digna de ser medida. Cada criterio se puntúa de 0 a 10, con un máximo teórico de 90 puntos:

Criterio	Letra	Definición operativa	Pregunta de evaluación
Predictive	P	Predice el comportamiento, estado o riesgo futuro	¿Permite anticipar problemas antes de que ocurran?
Relevant	R	Relevante para los objetivos de seguridad de la organización	¿Importa realmente a quienes toman decisiones?
Actionable	A	Permite tomar decisiones y acciones correctivas concretas	¿Qué acción concreta provoca un valor bajo?
Genuine	G	Mide realmente lo que afirma medir (no un proxy distante)	¿O mide algo que sólo se parece al objetivo?
Meaningful	M	Significativo para la audiencia a la que se presenta	¿Lo entiende quien necesita actuar?
Accurate	A	Datos suficientemente precisos para el uso previsto	¿El error de medición afecta las decisiones?
Timely	T	Disponible cuando se necesita, con la frecuencia adecuada	¿Llega a tiempo para ser útil?
Independent	I	Libre de conflictos de interés; no manipulable por quien se mide	¿Podría el medido influir en el resultado?
Cheap	C	Coste razonable de recopilar, procesar y mantener	¿El beneficio justifica el coste de medición?

Escala de interpretación del score PRAGMATIC total:

Score total (/90)	Calificación	Interpretación
81 - 90	★★★★★ Excelente	Métrica de referencia; adopción recomendada
71 - 80	★★★★☆ Muy buena	Métrica sólida; implementación directa
61 - 70	★★★☆☆ Buena	Métrica útil con mejoras menores
51 - 60	★★☆☆☆ Aceptable	Revisar criterios más débiles antes de adoptar
41 - 50	★☆☆☆☆ Débil	Rediseñar la métrica o sustituirla
< 40	✗ Inadecuada	Rechazar; buscar alternativa

2. ARQUITECTURA DEL MARCO INTEGRATIVO

2.1 Los Cuatro Niveles de Trazabilidad

NIVEL 0 – ESTRATEGIA NACIONAL

Estrategia Nacional de Ciberseguridad España 2025
Objetivos Estratégicos ENS / NIS2 / Anteproyecto Ley Ciberseg.

GQM+Strategies: ¿Qué estrategias apoyan este objetivo?

NIVEL 1 – OBJETIVOS INSTITUCIONALES (GQM: GOAL)

Objetivos de madurez por dominio FISMA
Formulados con plantilla: Analizar [X] con propósito de [Y]
con respecto a [Z] desde perspectiva de [W] en contexto de [V]

GQM Nivel 2: ¿Qué preguntas caracterizan el logro?

NIVEL 2 – PREGUNTAS DE CARACTERIZACIÓN (GQM: QUESTION)

Preguntas sobre estado actual, tendencia y comparación
Tipo 1: Caracterización | Tipo 2: Logro | Tipo 3: Mejora

GQM Nivel 3: ¿Qué dato responde la pregunta?

NIVEL 3 – MÉTRICAS TÉCNICAS (GQM: METRIC)

Indicadores FISMA FY2025 (20 core + 5 suplementarias)
Evaluados con PRAGMATIC (9 criterios × 0-10 = /90 puntos)

2.2 Principios de Diseño del Marco

1. Trazabilidad completa: Toda métrica debe poder trazarse hasta al menos un objetivo nacional o institucional. Si no puede, se elimina.
2. Accionabilidad garantizada: Toda métrica debe provocar una acción concreta cuando muestra un valor fuera de umbral. Si no, es decorativa.
3. Proporcionalidad al riesgo: Las métricas de dominios de mayor criticidad reciben mayor peso en el IGM (conforme al principio de proporcionalidad del ENS, Art. 14, y NIS2, Art. 21.1).
4. Independencia de medición: Las métricas de cumplimiento formal son validadas por auditor externo; las métricas de estado técnico por herramientas automatizadas.
5. Economía de medición: Siguiendo el criterio C de PRAGMATIC, se priorizan métricas obtenibles de infraestructura existente (SIEM, CDM, CMDB) antes de diseñar nuevos procesos de recolección.

3. APLICACIÓN DEL MARCO A LOS 10 DOMINIOS FISMA FY2025

DOMINIO I: CYBERSECURITY GOVERNANCE

Función CSF 2.0: GOVERN | **Métricas FISMA FY2025:** Gov-1 (Supl.), Gov-2 (Supl.), Gov-3 (Supl.)

GQM — Objetivo Institucional (GOAL):

Analizar el programa de gobernanza de ciberseguridad de la organización
con el propósito de evaluar si la dirección ejerce supervisión efectiva y rendición de cuentas
con respecto a la existencia, formalización y operatividad del programa de gobernanza
desde la perspectiva de la Alta Dirección, el CISO y el órgano de control
en el contexto de las AAPP españolas sujetas a ENS (RD 311/2022) y NIS2

Estrategia nacional vinculada: Eje 2 (Capacitación) y Eje 4 (Marco institucional) de la ENCS 2025; Art. 20 NIS2 (responsabilidad directiva); Art. 13 ENS.

GQM — Preguntas (QUESTIONS):

ID	Tipo	Pregunta de caracterización
Q-GOV-1	Caracterización	¿Existe un programa formal de gobernanza de ciberseguridad aprobado por el órgano directivo?
Q-GOV-2	Logro	¿En qué medida la alta dirección toma decisiones activas de ciberseguridad con datos y métricas?
Q-GOV-3	Mejora	¿Está definida y comunicada la tolerancia al riesgo cibernético de la organización?

GQM — Métricas (METRICS):

ID Métrica	Nombre FISMA	Dato requerido	Umbral efectividad
Gov-1	Cybersecurity Governance Program	% de elementos del programa formalizados (política, CISO, comité, KPIs)	≥ 4 de 5 elementos (Nivel 4)
Gov-2	Leadership Accountability	Frecuencia de revisión por la dirección + % de decisiones documentadas	Revisión ≥ trimestral; doc ≥ 80%
Gov-3	Risk Tolerance Statement	Existencia + fecha de aprobación + comunicación	Aprobada < 12 meses; comunicada a responsables

PRAGMATIC — Evaluación Métrica Gov-1:

- P(Predictivo):7 — Las brechas en gobernanza predicen mayor exposición a incidentes mayores
- R(Relevante):9 — Directamente exigido por NIS2 Art. 20 y ENS Art. 13
- A(Accionable):8 — Brecha clara → formalizar comité, aprobar política
- G(Genuino):7 — Mide existencia formal; puede no reflejar calidad real de gobernanza
- M(Significativo):9 — Lenguaje comprensible para la dirección
- A(Preciso):7 — Escala discreta de 5 elementos con criterios objetivos
- T(Oportuno):8 — Revisable anualmente; cambios detectables
- I(Independiente):7 — Auditoría externa válida; riesgo de autoengaño en autoevaluación
- C(Rentable):8 — Recopilación documental de bajo coste
- Score total Gov-1: 70/90 ★★★★★☆

DOMINIO II: CYBERSECURITY SUPPLY CHAIN RISK MANAGEMENT (C-SCRM)

Función CSF 2.0: GOVERN | Métricas FISMA FY2025: SCRM-1, SCRM-2, SCRM-3

GQM — Objetivo Institucional (GOAL):

Analizar la gestión del riesgo de la cadena de suministro TIC
con el propósito de evaluar si la organización identifica, evalúa y mitiga los riesgos de terceros
con respecto a la cobertura de proveedores críticos y la efectividad de controles contractuales
desde la perspectiva de el CISO, el responsable de contratación y el auditor
en el contexto de las AAPP españolas y su cadena de suministro tecnológico

Estrategia nacional vinculada: ENCS 2025 Eje 3 (Capacidades); NIST SP 800-161r1; Art. 21.2.d NIS2; Art. 19 ENS.

GQM — Preguntas (QUESTIONS):

ID	Tipo	Pregunta
Q-SCRM-1	Caracterización	¿Tiene la organización un inventario actualizado de proveedores con acceso a sistemas críticos?
Q-SCRM-2	Logro	¿Qué porcentaje de contratos TIC críticos incluyen cláusulas de ciberseguridad verificables?
Q-SCRM-3	Mejora	¿Se evalúa el riesgo cibernético de los proveedores antes de la adjudicación y durante el contrato?

GQM — Métricas (METRICS):

ID	Nombre FISMA	Dato	Umbral
SCRM-1	C-SCRM Plan and Policy	% de proveedores críticos inventariados y clasificados por nivel de riesgo	≥ 95% inventariados; ≥ 80% clasificados
SCRM-2	Supplier Risk Identification	% contratos TIC con cláusulas de seguridad activas	≥ 90% contratos nuevos; ≥ 70% contratos vigentes
SCRM-3	Supplier Risk Response	% proveedores de alto riesgo con plan de respuesta documentado	≥ 100% proveedores críticos; ≥ 75% alto riesgo

PRAGMATIC — Score resumen C-SCRM:

- SCRM-1: 67/90 ★★★★★ (débil en Genuino: inventario ≠ riesgo real gestionado)
- SCRM-2: 72/90 ★★★★★ (fuerte en Relevante y Accionable; débil en Barato por carga contractual)
- SCRM-3: 69/90 ★★★★★ (débil en Oportuno: evaluaciones típicamente anuales, insuficiente)

DOMINIO III: RISK AND ASSET MANAGEMENT

Función CSF 2.0: IDENTIFY | Métricas FISMA FY2025: RA-1, RA-2, RA-3

GQM — Objetivo Institucional (GOAL):

Analizar la gestión de activos y riesgos de los sistemas de información

con el propósito de verificar que todos los activos están identificados, clasificados y asociados a riesgos cuantificados

con respecto a la completitud del inventario, la corrección de la categorización y la calidad del análisis de riesgos

desde la perspectiva de el responsable de sistemas, el CISO y el auditor ENS
en el contexto de sistemas de información de las AAPP españolas

Estrategia vinculada: Art. 14 ENS (gestión de riesgos); MAGERIT v3; NIST SP 800-30; FIPS 199; Art. 21.2.a NIS2.

GQM — Preguntas:

ID	Pregunta
Q-RA-1	¿Qué porcentaje de activos de información de la organización están inventariados con atributos completos?
Q-RA-2	¿Los sistemas están correctamente categorizados según su nivel de impacto en la misión institucional?
Q-RA-3	¿Se realizan análisis de riesgos formales con frecuencia adecuada y metodología documentada?

GQM — Métricas:

ID	Nombre FISMA	Dato	Umbral
RA-1	Asset Inventory	% activos en CMDB con ≥ 6 atributos clave completos	$\geq 95\%$ (CDM reporting)
RA-2	System Categorization	% sistemas con categorización FIPS 199 / ENS vigente y aprobada	$\geq 100\%$ sistemas en producción
RA-3	Risk Assessment	% sistemas con AR formal < 3 años (< 1 año para Alto impacto)	$\geq 90\%$ sistemas

PRAGMATIC — Score resumen:

- RA-1: 74/90 ★★★★★☆ (fuerte; debilidad en Genuino si CMDB no se mantiene actualizada)
- RA-2: 76/90 ★★★★★☆ (muy sólida; binaria y objetiva)
- RA-3: 68/90 ★★★★★☆☆ (débil en Barato: AR formal consume recursos significativos)

DOMINIO IV: CONFIGURATION MANAGEMENT

Función CSF 2.0: PROTECT | **Métricas FISMA FY2025:** CM-1, CM-2, CM-3

GQM — Objetivo Institucional (GOAL):

Analizar los procesos de gestión de configuración y vulnerabilidades
con el propósito de reducir la superficie de ataque mediante líneas base seguras y parcheo oportuno
con respecto a la cobertura de hardening, el tiempo de aplicación de parches y la frecuencia de escaneo

de vulnerabilidades

desde la perspectiva de el equipo de operaciones de seguridad y el CISO
en el contexto de infraestructura TIC de las AAPP españolas

Estrategia vinculada: CISA KEV (Known Exploited Vulnerabilities); CIS Controls v8; medida ENS op.exp.4; NIST SP 800-40 Rev.4; Art. 21.2.e NIS2.

GQM — Preguntas:

ID	Pregunta
Q-CM-1	¿Qué porcentaje de sistemas siguen líneas base de configuración segura (hardening) aprobadas?
Q-CM-2	¿Cuál es el tiempo medio de aplicación de parches críticos desde publicación de CVE?
Q-CM-3	¿Con qué frecuencia y cobertura se realizan escaneos de vulnerabilidades?

GQM — Métricas:

ID	Nombre FISMA	Dato	Umbral FISMA / ENS
CM-1	Configuration Baselines	% sistemas con SCB (Secure Configuration Baseline) aplicada y verificada	≥ 95% GFE / ≥ 90% entornos AAPP
CM-2	Patch Management — Critical	MTTP (Mean Time To Patch) para CVE críticos (CVSS ≥ 9.0)	≤ 15 días (CISA KEV: ≤ 7 días para KEV activas)
CM-3	Vulnerability Scanning Coverage	% activos escaneados ≥ 1 vez/semana (críticos) / ≥ 1/mes (resto)	≥ 95% activos críticos; ≥ 80% resto

PRAGMATIC — Score resumen:

- CM-1: 72/90 ★★★★★☆ (muy accionable; débil en Genuino: cumplimiento formal vs. efectividad real)
- CM-2: 82/90 ★★★★★ — Mejor métrica de este dominio; predictiva, precisa, objetiva, accionable
- CM-3: 75/90 ★★★★★☆ (fuerte; leve debilidad en Barato si el parque es heterogéneo y legacy)

DOMINIO V: IDENTITY AND ACCESS MANAGEMENT (IDAM) / ZERO TRUST

Función CSF 2.0: PROTECT | **Métricas FISMA FY2025:** IDAM-1, IDAM-2, IDAM-3, ZTA-S1, ZTA-S2

GQM — Objetivo Institucional (GOAL):

Analizar los controles de identidad, autenticación y acceso

con el propósito de verificar que sólo los usuarios y dispositivos autorizados acceden a los recursos necesarios

con respecto a la cobertura de MFA, la correcta aplicación del mínimo privilegio y la gestión de accesos

privilegiados

desde la perspectiva de el CISO, el administrador de identidades y el auditor
en el contexto de la hoja de ruta Zero Trust del CCN y CISA ZTMM v2.0

Estrategia vinculada: OMB M-22-09 (Federal ZTA Strategy); CISA ZTMM v2.0; NIST SP 800-207;
medida ENS mp.acc; Art. 21.2.i y 21.2.j NIS2.

GQM — Preguntas:

ID	Pregunta
Q-IDAM-1	¿Qué porcentaje de usuarios (privilegiados y estándar) utilizan MFA para acceder a sistemas corporativos?
Q-IDAM-2	¿Con qué frecuencia se revisan y certifican los permisos de acceso?
Q-IDAM-3	¿Existen controles PAM para todas las cuentas de administración?
Q-ZTA-1	¿En qué pilares de Zero Trust ha avanzado la organización según CISA ZTMM v2.0?

GQM — Métricas:

ID	Nombre FISMA	Dato	Umbral
IDAM-1	MFA Implementation	% usuarios con MFA activado (separado: privilegiados vs. estándar)	100% privilegiados; ≥ 90% estándar
IDAM-2	Access Reviews / Least Privilege	% cuentas con revisión formal de permisos < 6 meses	≥ 90% cuentas activas
IDAM-3	Privileged Account Management	% cuentas privilegiadas gestionadas por solución PAM con grabación de sesiones	≥ 95%
ZTA-S1	Zero Trust Data Management	Nivel de madurez en pilar "Datos" CISA ZTMM (1-4)	≥ Nivel 2 (Avanzado)
ZTA-S2	Zero Trust Asset Integrity	Nivel madurez en pilar "Dispositivos" CISA ZTMM (1-4)	≥ Nivel 2

PRAGMATIC — Score resumen:

- IDAM-1: 84/90 ★★★★★ — Métrica ejemplar: precisa, binaria, universalmente accionable
- IDAM-2: 73/90 ★★★★★☆ (leve debilidad en Barato: revisiones manuales costosas a escala)
- IDAM-3: 78/90 ★★★★★☆ (muy fuerte; débil en Genuino si PAM no se usa activamente)
- ZTA-S1/S2: 65/90 ★★★★★☆ (emergentes; débiles en Preciso por subjetividad del nivel ZTMM)

DOMINIO VI: DATA PROTECTION AND PRIVACY

Función CSF 2.0: PROTECT | Métricas FISMA FY2025: DP-1, DP-2, DP-3

GQM — Objetivo Institucional (GOAL):

Analizar los controles de protección de datos y privacidad
con el propósito de garantizar que los datos sensibles están inventariados, clasificados y cifrados
con respecto a la completitud del inventario de datos, la cobertura de cifrado y la realización de DPIAs
desde la perspectiva de el DPO, el CISO y el equipo jurídico
en el contexto de tratamientos de datos personales bajo RGPD/LOPDGDD y datos sensibles bajo ENS

Estrategia vinculada: RGPD (UE 2016/679); LOPDGDD (LO 3/2018); NIST SP 800-175B; FIPS 140-3; NIST FIPS 203/204/205 (PQC).

GQM — Preguntas:

ID	Pregunta
Q-DP-1	¿Existe un inventario o mapa de datos completo con clasificación por nivel de sensibilidad?
Q-DP-2	¿Qué porcentaje de datos en reposo y en tránsito clasificados como sensibles o superiores están cifrados?
Q-DP-3	¿Se realizan DPIAs para todos los tratamientos de alto riesgo?

GQM — Métricas:

ID	Nombre	Dato	Umbral
DP-1	Data Classification & Inventory	% repositorios de datos con clasificación formal documentada	≥ 90% repositorios activos
DP-2	Encryption Coverage	% datos sensibles cifrados en reposo (AES-256) y en tránsito (TLS 1.3+)	≥ 100% datos sensibles y clasificados
DP-3	DPIA Completion	% tratamientos de alto riesgo con DPIA realizada y actualizada < 2 años	≥ 100% tratamientos alto riesgo

PRAGMATIC — Score resumen:

- DP-1: 68/90 ★★★★★ (débil en Genuino: clasificar ≠ proteger; y en Barato: taxonomía costosa)
- DP-2: 79/90 ★★★★★ (muy fuerte y objetiva; débil en Genuino si el cifrado no está gestionado centralmente)
- DP-3: 74/90 ★★★★★ (fuerte en Relevante y Accionable; débil en Oportuno: DPIAs lentas)

DOMINIO VII: SECURITY TRAINING

Función CSF 2.0: PROTECT | Métricas FISMA FY2025: ST-1, ST-2

GQM — Objetivo Institucional (GOAL):

Analizar el programa de formación y concienciación en ciberseguridad
con el propósito de reducir el riesgo humano mediante capacitación efectiva y cambio de comportamiento
con respecto a la cobertura del programa, su calidad y el comportamiento resultante de los usuarios
desde la perspectiva de el CISO, RRHH y la dirección
en el contexto de las obligaciones de formación del ENS (Arts. 15-16) y NIS2 (Arts. 20.2, 21.2.j)

GQM — Preguntas:

ID	Pregunta
Q-ST-1	¿Qué porcentaje de empleados completa anualmente la formación obligatoria en ciberseguridad?
Q-ST-2	¿Cómo evoluciona la tasa de clics en simulacros de phishing a lo largo del tiempo?

GQM — Métricas:

ID	Nombre	Dato	Umbral
ST-1	Security Awareness Training Completion	% personal con formación anual completada y certificada	≥ 90% plantilla; 100% perfiles privilegiados
ST-2	Phishing Simulation Click Rate	% empleados que hacen clic en simulacro phishing (tendencia trimestral)	< 5% click rate; tendencia descendente YoY

PRAGMATIC — Score resumen:

- ST-1: 71/90 ★★★★★ (fuerte; débil en Predictivo y Genuino: completar formación ≠ cambio de conducta)
- ST-2: 76/90 ★★★★★ (más genuina que ST-1; débil en Independiente si el proveedor gestiona también los resultados)

DOMINIO VIII: INFORMATION SECURITY CONTINUOUS MONITORING (ISCM)

Función CSF 2.0: DETECT | Métricas FISMA FY2025: ISCM-1, ISCM-2, ISCM-3, ISCM-4

GQM — Objetivo Institucional (GOAL):

Analizar el programa de monitorización continua de seguridad
con el propósito de detectar amenazas y anomalías en tiempo real con cobertura suficiente
con respecto a la cobertura del SIEM, EDR y logging, y el tiempo medio de detección
desde la perspectiva de el SOC, el CISO y el equipo de operaciones
en el contexto de los requisitos del CCN-STIC (Series 400 y 800) y OMB M-21-31 (log management)

GQM — Preguntas:

ID	Pregunta
Q-ISCM-1	¿Qué porcentaje de activos críticos envían logs al SIEM con retención conforme a M-21-31?
Q-ISCM-2	¿Qué porcentaje de endpoints gestionados tienen EDR/XDR activo y actualizado?
Q-ISCM-3	¿Cuál es el tiempo medio de detección (MTTD) de incidentes de seguridad?
Q-ISCM-4	¿Consume la organización CTI (Cyber Threat Intelligence) de fuentes externas verificadas?

GQM — Métricas:

ID	Nombre	Dato	Umbral
ISCM-1	SIEM Coverage & Log Retention	% activos críticos con logging activo + retención ≥ 12 meses (nivel EL3 M-21-31)	≥ 90% activos críticos
ISCM-2	EDR/XDR Coverage	% endpoints gestionados con EDR activo y firmas < 24h de antigüedad	≥ 95%
ISCM-3	Mean Time to Detect (MTTD)	Días desde compromiso hasta detección (mediana mensual)	≤ 1 día (objetivo); ≤ 7 días (mínimo FISMA L4)
ISCM-4	CTI Consumption & Integration	Nº fuentes CTI formales integradas + % alertas correlacionadas con IOCs externos	≥ 3 fuentes; ≥ 30% alertas enriquecidas

PRAGMATIC — Score resumen:

- ISCM-1: 73/90 ★★★★★☆ (fuerte; débil en Barato si se requiere ingeniería de datos de logging)
- ISCM-2: 80/90 ★★★★★☆ (muy fuerte; objetiva y automatizable)
- ISCM-3: 77/90 ★★★★★☆ (muy predictiva; débil en Preciso: MTTD difícil de calcular sin IR previo)
- ISCM-4: 64/90 ★★★★★☆☆ (emergente; débil en Preciso y Barato)

DOMINIO IX: INCIDENT RESPONSE

Función CSF 2.0: RESPOND | Métricas FISMA FY2025: IR-1, IR-2, IR-3

GQM — Objetivo Institucional (GOAL):

Analizar la capacidad de respuesta a incidentes de seguridad

con el propósito de evaluar si la organización puede contener, erradicar y recuperarse de incidentes en plazos aceptables

con respecto a la existencia del IRP, su prueba y los tiempos reales de respuesta

desde la perspectiva de el equipo de IR, el CISO y la autoridad competente (CCN-CERT / INCIBE-CERT)

en el contexto de las obligaciones de notificación del ENS (CCN-STIC 817) y NIS2 (Art. 23: 24h/72h/1 mes)

GQM — Preguntas:

ID	Pregunta
Q-IR-1	¿Existe un Plan de Respuesta a Incidentes formal, aprobado y conocido por el equipo?
Q-IR-2	¿Con qué frecuencia se prueban las capacidades de respuesta a incidentes?
Q-IR-3	¿Cuáles son los tiempos reales de contención y erradicación de incidentes críticos?

GQM — Métricas:

ID	Nombre	Dato	Umbral
IR-1	Incident Response Plan	Existencia + fecha aprobación + cobertura de escenarios (ransomware, phishing, breach, DDoS)	Plan aprobado < 12 meses; ≥ 5 escenarios cubiertos
IR-2	IR Testing Frequency	Número de ejercicios de IR (tabletop + técnico) en los últimos 12 meses	≥ 2 ejercicios/año (1 tabletop + 1 técnico mínimo)
IR-3	MTTC (Mean Time to Contain)	Tiempo medio de contención de incidentes críticos (horas)	≤ 4 horas (críticos); ≤ 24 horas (altos)

PRAGMATIC — Score resumen:

- IR-1: 72/90 ★★★★★☆ (fuerte; débil en Genuino: plan ≠ capacidad real)
- IR-2: 74/90 ★★★★★☆ (buena; débil en Predictivo: frecuencia ≠ calidad del ejercicio)
- IR-3: 80/90 ★★★★★☆ (excelente métrica de resultado; débil en Barato si no hay SOAR/SIEM automatizado)

DOMINIO X: CONTINGENCY PLANNING

Función CSF 2.0: RECOVER | **Métricas FISMA FY2025:** CP-1, CP-2

GQM — Objetivo Institucional (GOAL):

Analizar los planes de continuidad y recuperación ante desastres
con el propósito de garantizar que la organización puede mantener o restaurar funciones esenciales tras un incidente disruptivo
con respecto a la existencia, prueba y cumplimiento de RTO/RPO de los planes de continuidad
desde la perspectiva de el responsable de continuidad, el CISO y la dirección
en el contexto de las obligaciones del ENS (Art. 26), NIS2 (Art. 21.2.c) e ISO 22301

GQM — Preguntas:

ID	Pregunta
Q-CP-1	¿Están documentados el BCP y el DRP con RTO y RPO formalmente definidos y aprobados?
Q-CP-2	¿Se prueban los planes de continuidad con la frecuencia adecuada y se documenta el resultado?

GQM — Métricas:

ID	Nombre	Dato	Umbral
CP-1	Contingency Plan Documentation	% sistemas críticos con BCP/DRP con RTO/RPO definidos y aprobados < 12 meses	100% sistemas de impacto Alto/Muy Alto
CP-2	Contingency Plan Testing	Frecuencia de pruebas + % sistemas críticos probados en últimos 12 meses	≥ 1 prueba completa/año; ≥ 100% sistemas críticos

PRAGMATIC — Score resumen:

- CP-1: 71/90 ★★★★★☆ (fuerte en Relevante; débil en Genuino: RTO en papel ≠ RTO real alcanzable)
- CP-2: 74/90 ★★★★★☆ (buena; débil en Barato: pruebas de continuidad son costosas y disruptivas)

4. INTEGRACIÓN: ÁRBOL GQM COMPLETO (RESUMEN)

ESTRATEGIA NACIONAL CIBERSEGURIDAD ESPAÑA 2025

- GOAL-I: Gobernanza efectiva → Q-GOV-1/2/3 → Gov-1, Gov-2, Gov-3
- GOAL-II: Cadena suministro segura → Q-SCRM-1/2/3 → SCRM-1, SCRM-2, SCRM-3
- GOAL-III: Activos y riesgos gestionados → Q-RA-1/2/3 → RA-1, RA-2, RA-3
- GOAL-IV: Superficie de ataque minimizada → Q-CM-1/2/3 → CM-1, CM-2, CM-3
- GOAL-V: Identidad y acceso controlados → Q-IDAM-1/2/3/4 → IDAM-1/2/3, ZTA-S1/S2
- GOAL-VI: Datos protegidos y privacidad garantizada → Q-DP-1/2/3 → DP-1, DP-2, DP-3
- GOAL-VII: Capital humano ciberseguro → Q-ST-1/2 → ST-1, ST-2
- GOAL-VIII: Detección continua y oportuna → Q-ISCM-1/2/3/4 → ISCM-1/2/3/4
- GOAL-IX: Respuesta a incidentes eficaz → Q-IR-1/2/3 → IR-1, IR-2, IR-3
- GOAL-X: Continuidad y recuperación garantizadas → Q-CP-1/2 → CP-1, CP-2

Total: 10 objetivos | 29 preguntas | 25 métricas (20 core + 5 suplementarias)

Kit GQM+PRAGMATIC FISMA 2025 — Marco Integrativo · Versión 1.0 · Abril 2026

Fuentes: Basili et al. (1994) GQM; Brotby & Hinson (2013) PRAGMATIC; OMB M-25-04; FY2025 IG FISMA Metrics v2.0; NIST CSF 2.0; RD 311/2022 ENS; Directiva NIS2 2022/2555